

Security & System Audit Report

Date: April 25, 2026 **Scope:** ZAIZEN Accounting Backend (.NET) & Frontend (React)

■ Critical Security Vulnerabilities (Identified)

1. Insecure Direct Object Reference (IDOR) on Company Data

- **Issue:** Endpoints in `JournalEntriesController`, `ExpensesController`, and others take a `companyId` query parameter but do not verify if the authenticated user is actually a member of that company.
- **Impact:** A logged-in user can potentially access financial data of *any* company by guessing their GUID.
- **Remedy:** Apply the existing `CompanyMembershipActionFilter` to all company-scoped controllers.

2. Weak Default Security Key

- **Issue:** `Program.cs` contains a fallback hardcoded JWT key: `"DevKeyForLocalDevelopmentOnly123456"`.
- **Impact:** If environment variables are misconfigured in production, the system falls back to a known weak key, allowing attackers to forge tokens.
- **Remedy:** Update logic to crash or fail securely if `JWT_KEY` is missing in a non-Development environment.

■■ API & Workflow Issues

1. Lack of Input Validation in DTOs

- **Issue:** Most DTOs (Data Transfer Objects) lack `[Required]`, `[Range]`, or `[MaxLength]` attributes.
- **Impact:** The database might receive malformed data (e.g. empty strings where names are expected), leading to UI breakage or inconsistent reporting.
- **Remedy:** Add `DataAnnotation` validation to all DTO classes and verify `ModelState.IsValid` in controllers.

2. Unconventional SQL Migrations in Program.cs

- **Issue:** Substantial raw SQL logic is executed inside `Program.cs` for backfilling data.
- **Impact:** Harder to maintain and test. Potential for race conditions during horizontal scaling.
- **Remedy:** Move database backfills and seed logic to dedicated EF Core Migrations or a robust `IDbInitializer` service.

■ Workflow Strengths

- **Immutable Audit Service:** Correct implementation of WORM patterns for financial integrity.
- **RBAC Architecture:** The permission-based authorization system is robust and scalable.
- **Exception Middleware:** `GlobalExceptionHandler` ensures internal stack traces aren't leaked to users.

■ Roadmap for Stabilization

1. **Phase 1 (Security):** Apply `CompanyMembershipActionFilter` globally or to all relevant controllers.
2. **Phase 2 (Validation):** Add model validation to core DTOs (Journal, Payroll, CRM).
3. **Phase 3 (Refactor):** Decouple database seeding from `Program.cs` into a startup background task.